

BUSINESS ASSOCIATE AGREEMENT

Reference Number: BAA-EDB641A631

Date Approved: 9/27/2026

PARTIES

Covered Entity (Clinic): Hello World
Authorized Signatory: Ankur (Clinic Owner)
Business Associate: OpenORDO Platform

AGREEMENT TERMS

HIPAA Business Associate Agreement

Last updated: 24 September 2026

This Business Associate Agreement ("**BAA**") is between **OpenORDO** ("**Business Associate**", "**OpenORDO**") and the clinic or practice that has accepted it ("**Covered Entity**", "**Customer**"). It applies where Customer is a **covered entity, or a business associate of a covered entity, under the US Health Insurance Portability and Accountability Act of 1996** and its regulations, as amended by the HITECH Act ("**HIPAA**"), and uses OpenORDO to create, receive, maintain or transmit **Protected Health Information** ("**PHI**").

About this agreement

- **Who needs it:** US-based healthcare providers, and others subject to HIPAA. **Clinics outside the United States generally do not need a BAA**; their data is covered by the [DPA](/legal/dpa) and applicable local laws (for example India's Digital Personal Data Protection Act, 2023).
- **Availability:** the BAA is available for **paid plans** (Practice and Clinic Group) and for add-ons used with those plans. It is not offered for the free Starter plan.
- **How to accept:** the Clinic Owner requests it at support@openordo.com (or from Settings, if the option is available). It takes effect on the date OpenORDO confirms in writing (the '**BAA Effective Date**'). A countersigned copy is provided on request.
- **PHI is only covered if Customer is subject to HIPAA.** OpenORDO does not determine whether Customer is a covered entity.
- **HIPAA is a shared responsibility.** Signing this BAA does not by itself make a clinic HIPAA compliant.

1. Definitions

Capitalised terms not defined here have the meaning in HIPAA (45 C.F.R. Parts 160 and 164). **PHI** means Protected Health Information, limited to what Business Associate creates, receives, maintains or transmits for Customer through the Services, and includes electronic PHI ("**ePHI**"). **"Services"** means the OpenORDO service and any add-ons Customer has purchased. **"Security Incident"**, **"Breach"**, **"Unsecured PHI"**, **"Designated Record Set"** and **"Minimum Necessary"** have the meanings in HIPAA.

2. Permitted uses and disclosures by Business Associate

Business Associate may use and disclose PHI **only**:

1. to provide the Services to Customer, in line with the [Terms of Service](/legal/terms) and this BAA (including hosting, storing, backing up, transmitting, displaying and supporting Customer's data);
2. for the **proper management and administration** of Business Associate, or to carry out its legal responsibilities, provided that any disclosure is required by law or Business Associate obtains reasonable assurances from the recipient that the PHI will remain confidential, be used or further disclosed only as required by law or for the purpose it was disclosed, and that the recipient will notify Business Associate of any breach;
3. to provide **data aggregation** services relating to Customer's health care operations, if Customer asks for them;
4. to create **de-identified** data in accordance with 45 C.F.R. § 164.514, only if Customer agrees in writing;
5. as **required by law**.

Business Associate will **not** use or disclose PHI in a way that would violate HIPAA if done by Customer (except as permitted above), will **not sell** PHI, and will not use PHI for marketing or fundraising. Business Associate will use, disclose and request only the **Minimum Necessary** PHI for these purposes.

3. Safeguards

Business Associate will:

1. use appropriate **administrative, physical and technical safeguards**, and comply with the HIPAA Security Rule (Subpart C of 45 C.F.R. Part 164) for ePHI, to prevent use or disclosure of PHI other than as this BAA allows;
2. maintain the security measures described in [Security & Trust](/legal/security) and Annex 2 of the [DPA](/legal/dpa), including encryption in transit, encryption at rest by infrastructure providers, role-based access, audit logging and tenant isolation;
3. limit access to PHI to workforce members with a need to know, who are trained and bound by confidentiality.

4. Reporting

Business Associate will report to Customer:

1. **any use or disclosure of PHI not permitted by this BAA** of which it becomes aware;
2. **any Security Incident** of which it becomes aware, and any **Breach of Unsecured PHI** (as required by 45 C.F.R. § 164.410).

Timing. Business Associate will report a Breach of Unsecured PHI, or an impermissible use or disclosure, **without unreasonable delay and in any event within five (5) business days** after discovery. Reports will include, to the extent known, the identity of affected individuals, what happened, what PHI was involved, what Business Associate is doing to mitigate and prevent recurrence, and a contact point. Business Associate will supplement the report as information becomes available. Business Associate will mitigate, to the extent practicable, any harmful effect of the improper use or disclosure.

Unsuccessful attempts. Customer acknowledges that this section constitutes notice of **unsuccessful Security Incidents** that do not result in unauthorised access to PHI, such as pings, port scans, denied log-on attempts and denial-of-service attacks that are blocked. No further notice of these will be given.

Customer notifications. Customer is responsible for notifying affected individuals, the US Department of Health and Human Services (HHS), and the media where required. Business Associate will not notify individuals or regulators about a Customer's Breach unless required by law or authorised by Customer.

5. Subcontractors

Business Associate will ensure that any subcontractor that creates, receives, maintains or transmits PHI on its behalf **agrees in writing to the same restrictions and conditions** that apply to Business Associate under this BAA (45 C.F.R. §§ 164.502(e)(1)(ii) and 164.308(b)(2)). For PHI, Business Associate will use a subcontractor only if it has signed (or agrees to sign) a business associate agreement or equivalent HIPAA-compliant terms.

Payment and email services. Customer agrees not to put PHI into fields that are sent to payment or email services (for example billing descriptions or Razorpay metadata, or emails). OpenORDO's design keeps clinical data out of these services.

6. Individual rights

Where Business Associate maintains PHI in a **Designated Record Set**, it will help Customer meet its obligations to individuals:

1. **Access (§ 164.524):** the Services allow Customer to search, view and export records. If an individual asks Business Associate directly, Business Associate will refer them to Customer within **10 business days**.

2. **Amendment (§ 164.526):** Customer can edit records within the Services. Business Associate will make available PHI for amendment and incorporate amendments as Customer directs.

3. **Accounting of disclosures (§ 164.528):** Business Associate will document disclosures of PHI that require an accounting and, within **15 business days** of a written request, provide the information Customer needs to respond.

7. Books and records

Business Associate will make its internal practices, books and records relating to the use and disclosure of PHI available to the **Secretary of HHS** for determining Customer's compliance with HIPAA, as required by law, and will notify Customer of any such request unless prohibited by law.

8. Customer obligations

Customer will:

1. use the Services in compliance with HIPAA and not ask Business Associate to use or disclose PHI in a way that would violate HIPAA;

2. give patients any **notice of privacy practices** and obtain any **authorisations or consents** HIPAA requires, and tell Business Associate of any restriction, revocation or limit that may affect Business Associate's use or disclosure of PHI (within 10 business days);

3. **configure and manage the Services securely:** assign appropriate roles, keep credentials confidential, remove users who leave, and not share logins;

4. enter only the **minimum necessary** PHI, and not put PHI in places that are not designed for it (such as email subjects, plan names, or the public booking page);

5. **ensure the video consultation add-on is used in a HIPAA-compliant manner** (identifying patients, obtaining consent, not recording without appropriate safeguards). OpenORDO does not record consultations; where the Customer records, the Customer is responsible for the recording;

6. **promptly tell Business Associate** at support@openordo.com of any suspected compromise of its accounts.

9. Term and termination

1. This BAA starts on the BAA Effective Date and lasts as long as Business Associate holds PHI for Customer, unless terminated earlier under this Section.

2. **Termination for cause.** If either party materially breaches this BAA, the other may terminate this BAA and the affected Services if the breach is not cured within **30 days** of written notice. If cure is not possible, the non-breaching party may terminate immediately.

3. **Effect of termination.** At termination of the Services, Business Associate will, if feasible, **return or destroy all PHI** it still maintains, and will not keep copies. Customer may export its data during the export window in [Data Retention](/legal/retention) and Business Associate will then delete PHI as described there, and confirm in writing on request. If return or destruction is **not feasible** (for example data in backups that cannot be selectively removed until they expire), Business Associate will extend the protections of this BAA to that PHI and limit further use and disclosure to the purposes that make return or destruction infeasible, until it is destroyed on the backup schedule.

10. Relationship to other agreements

- This BAA supplements the [Terms of Service](/legal/terms) and the [DPA](/legal/dpa). For PHI, if they conflict, **this BAA prevails.**
- The limitations of liability in the Terms apply to this BAA to the extent HIPAA and other applicable law allow.
- Nothing in this BAA gives any third party rights, or makes Business Associate a healthcare provider or Customer's agent for other purposes. Business Associate is an independent contractor.

11. Amendment and interpretation

The parties will amend this BAA as needed to comply with changes to HIPAA. Any ambiguity is resolved to permit compliance with HIPAA. References to HIPAA sections mean those sections as amended. This BAA is governed by the same law as the Terms, except to the extent HIPAA preempts it.

12. Notices and contact

| Purpose | Contact |

|---|---|

| Request or countersign a BAA | support@openordo.com |

| Report a Security Incident or suspected Breach | support@openordo.com |

| Privacy questions | support@openordo.com |

OpenORDO, Chandigarh, India

IN WITNESS WHEREOF, the parties hereto have executed this Agreement.

For: Hello World

By: Ankur

Title: Clinic Owner

For: OpenORDO Platform

By: Super Admin

Date: 9/27/2026